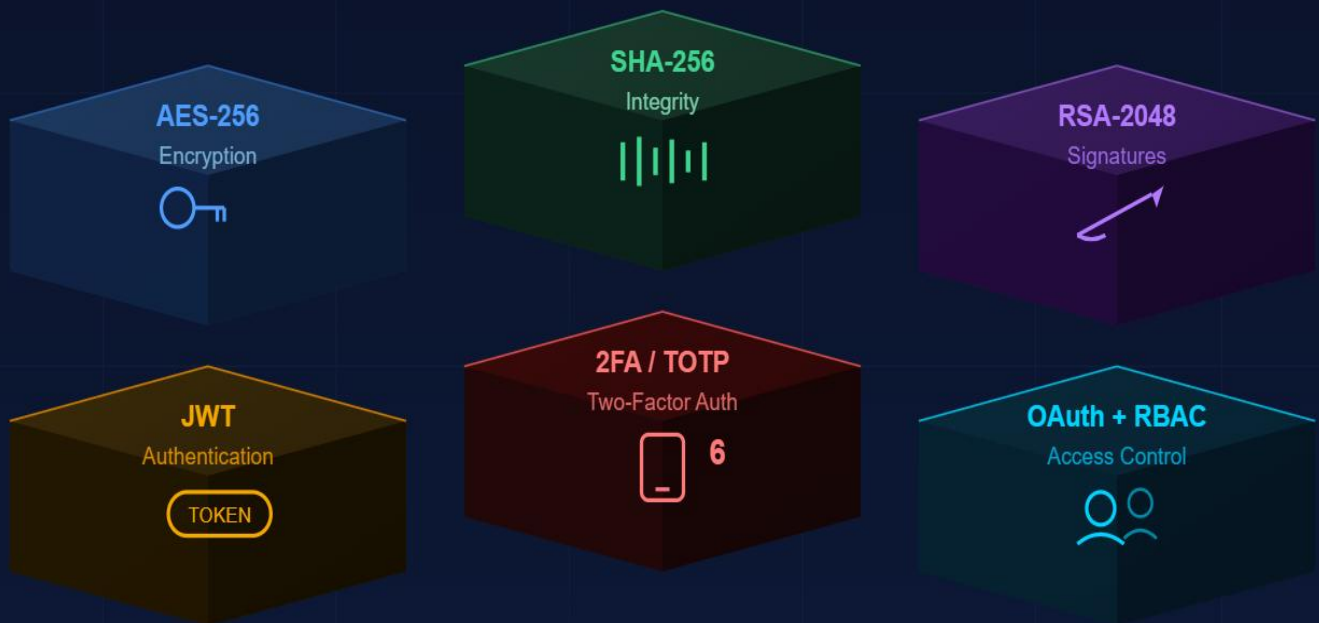




Secure Document Vault

SYSTEM



Alexandria National University

Faculty of Computers and Data Science · Cyber Security

Node.js

React.js

PostgreSQL

bcrypt

HTTPS/TLS

1. Project Overview

The Secure Document Vault System is a full-stack web application designed to demonstrate real-world security practices in document management. The system allows users to securely upload, store, encrypt, digitally sign, and verify documents while enforcing modern authentication and authorization mechanisms.

This project was developed as the final deliverable for the Data Integrity and Authentication course, simulating an enterprise-grade secure platform.

2. Project Objectives

The main objectives of this project are:

- Implement modern authentication mechanisms including JWT, OAuth, and 2FA
- Apply secure password storage using bcrypt hashing with policy enforcement
- Implement Role-Based Access Control (RBAC) with Admin, Manager, and User roles
- Encrypt uploaded documents using AES-256 symmetric encryption
- Generate SHA-256 hashes and RSA digital signatures for integrity verification
- Secure communication using HTTPS with SSL/TLS certificates
- Demonstrate the importance of HTTPS through Wireshark traffic analysis

3. Technology Stack

Layer	Technology	Purpose
Backend	Node.js + Express.js	RESTful API server
Frontend	React.js + Vite	User Interface
Database	PostgreSQL + Sequelize	Data persistence & ORM
Authentication	JWT + Passport.js	Token-based auth & OAuth
Encryption	Node.js crypto (AES-256)	Document encryption
Hashing	SHA-256	Integrity verification
Digital Signatures	RSA-2048	Document signing
2FA	Speakeasy + Google Auth	Two-factor authentication
HTTPS	Self-signed SSL (mkcert)	Secure communication
Password Hashing	bcryptjs	Secure password storage

4. System Architecture

The system follows a three-tier client-server architecture:

- Presentation Layer: React.js frontend running on port 5173
- Application Layer: Node.js/Express backend API running on port 5000 (HTTPS)
- Data Layer: PostgreSQL database storing user and document metadata

All communication between layers is secured via HTTPS/TLS. Documents are encrypted at rest using AES-256 before storage on the filesystem.

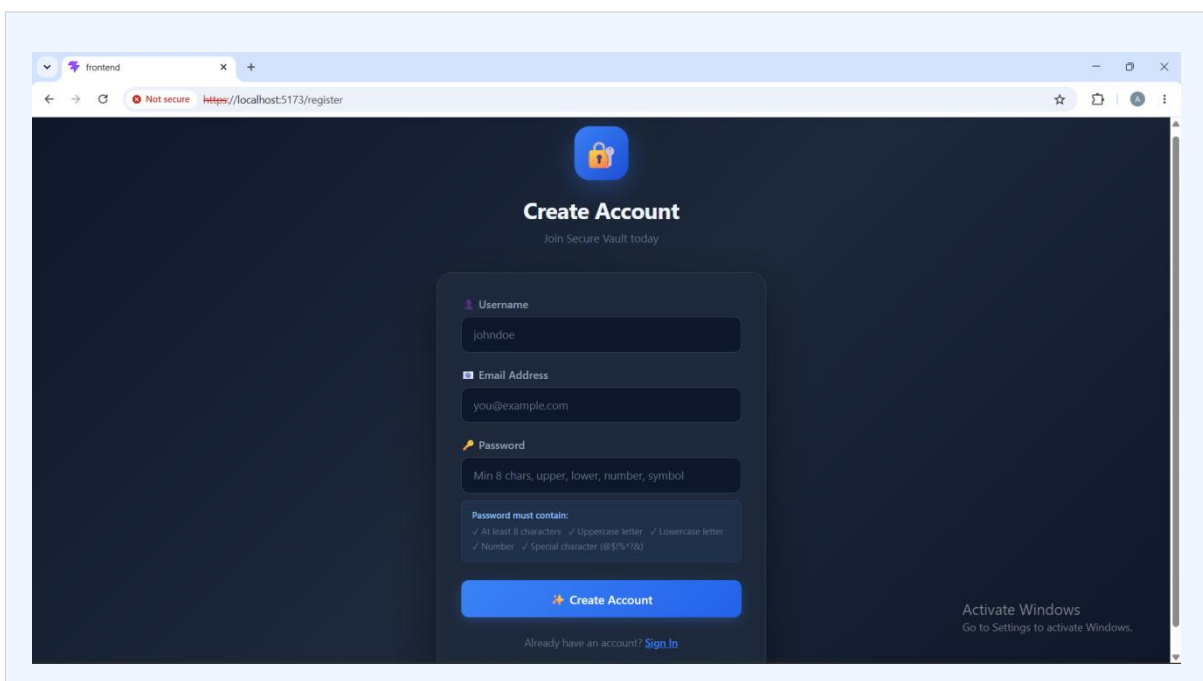
5. Security Features Implementation

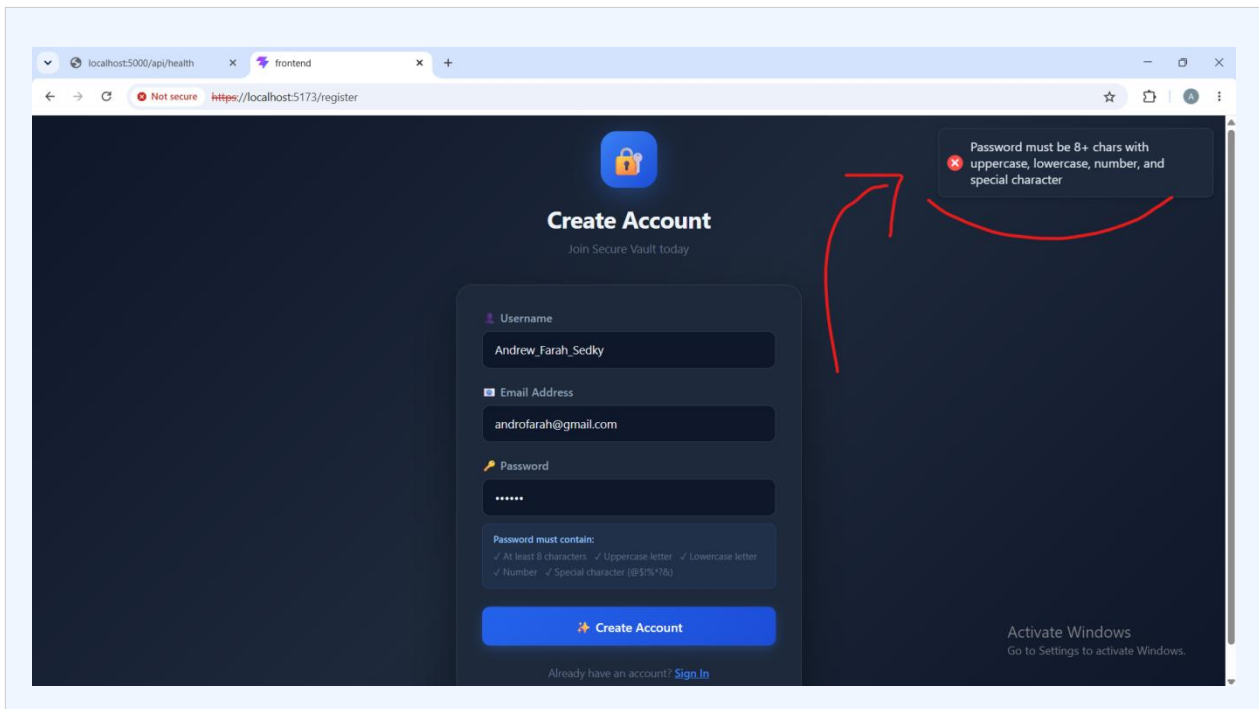
5.1 User Registration & Password Policy

Users register with a username, email, and password. Passwords are validated against a strict policy before hashing:

- Minimum 8 characters
- At least one uppercase letter (A-Z)
- At least one lowercase letter (a-z)
- At least one digit (0-9)
- At least one special character (@\$!%*?&)

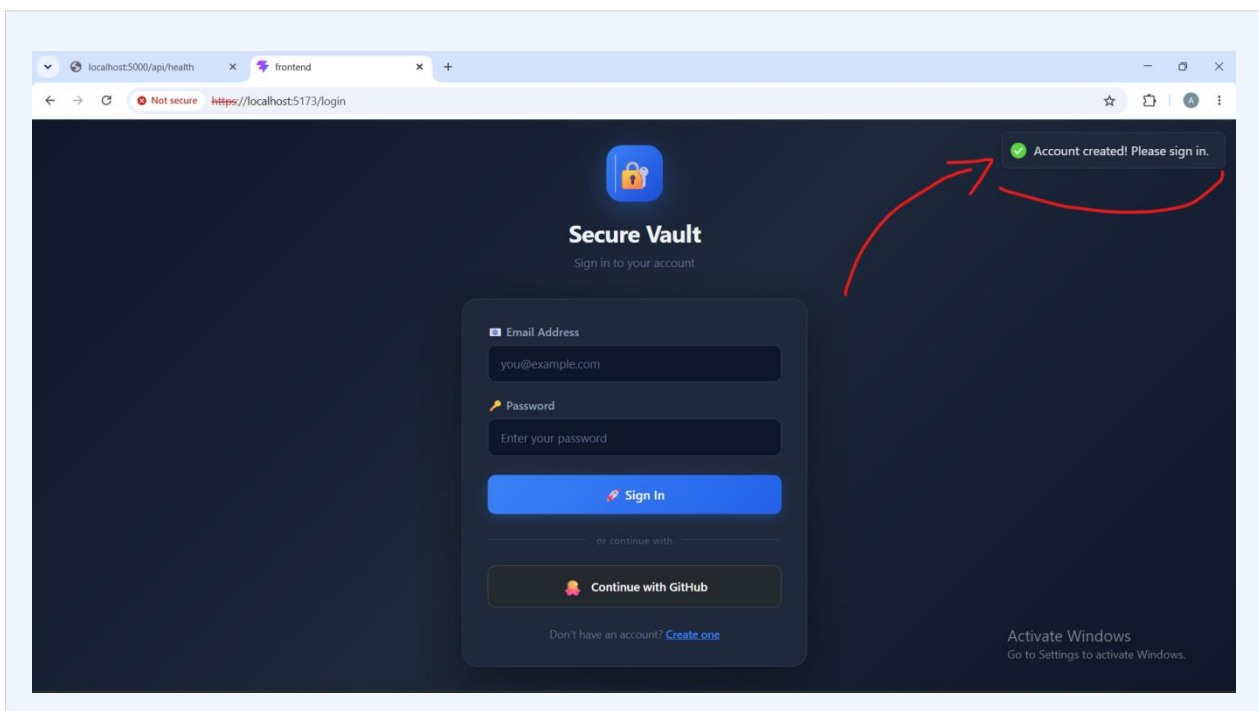
Passwords are hashed using bcrypt with a cost factor of 12 before being stored in the database. Plain-text passwords are never stored.

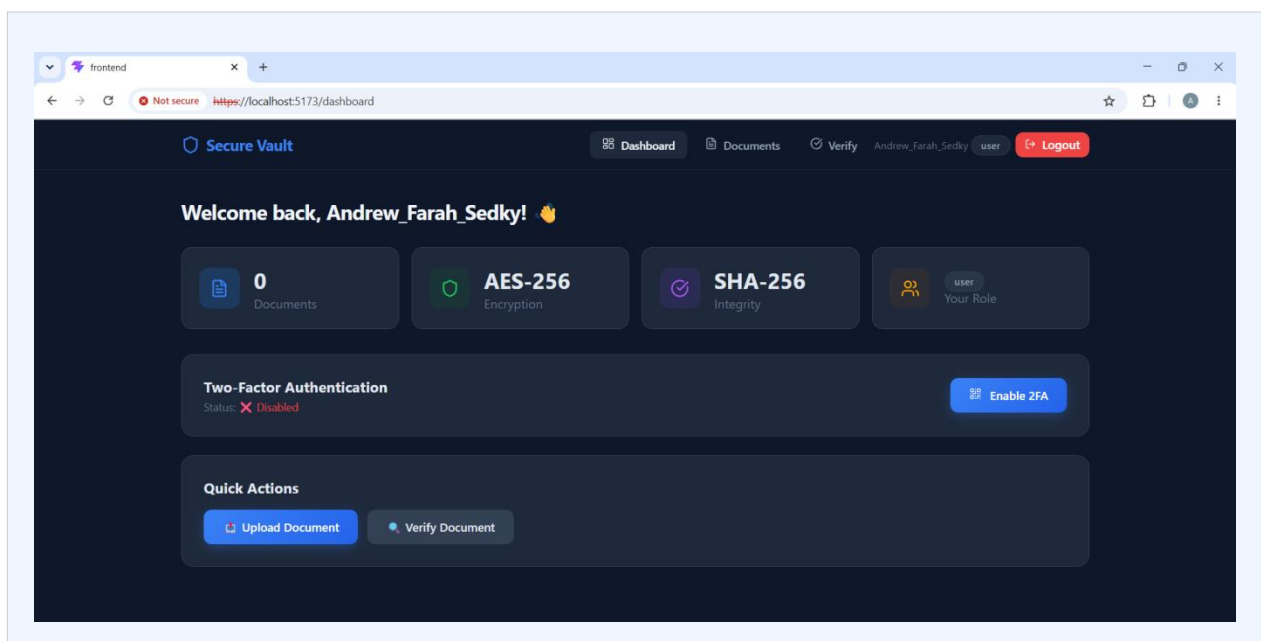
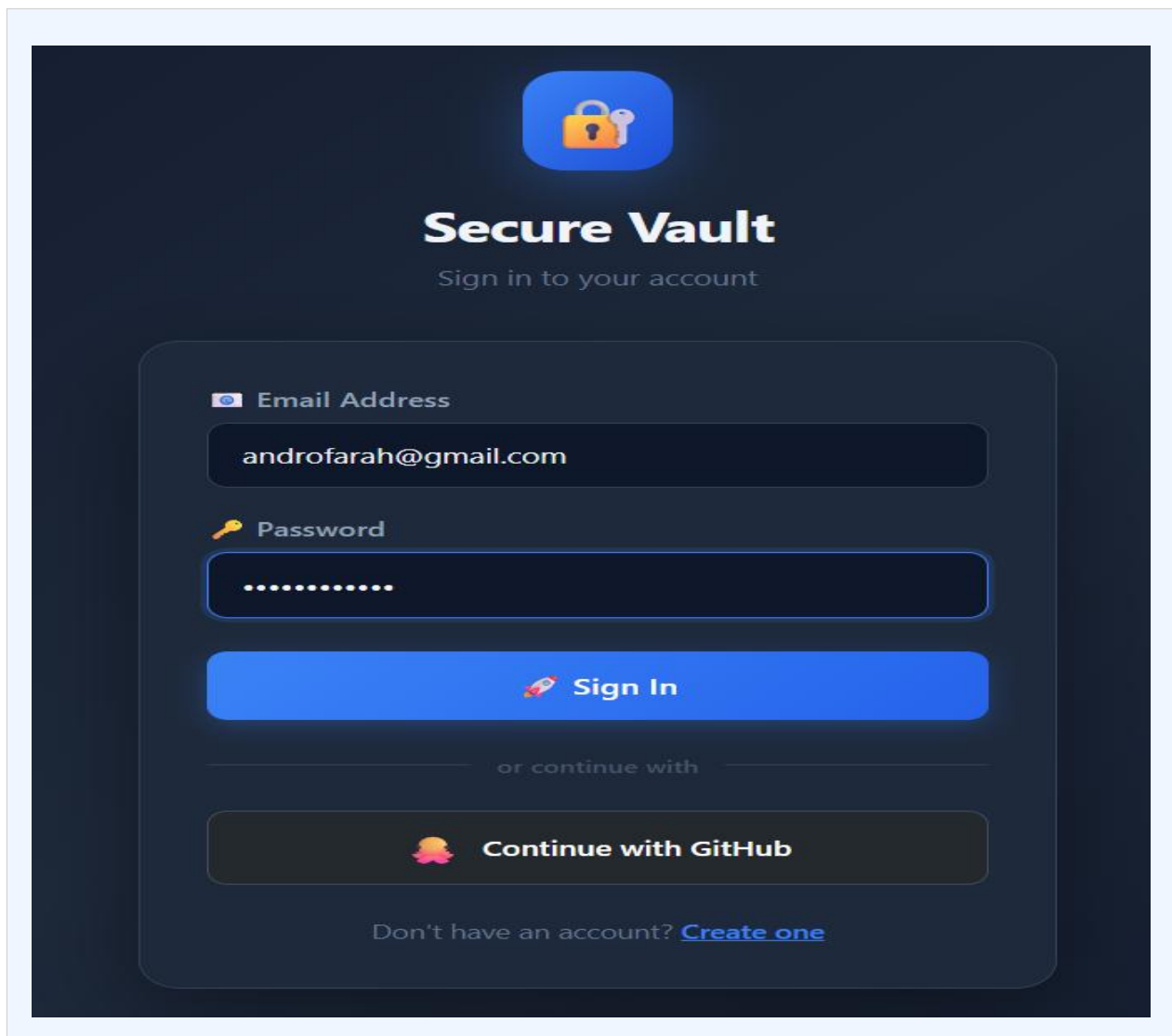


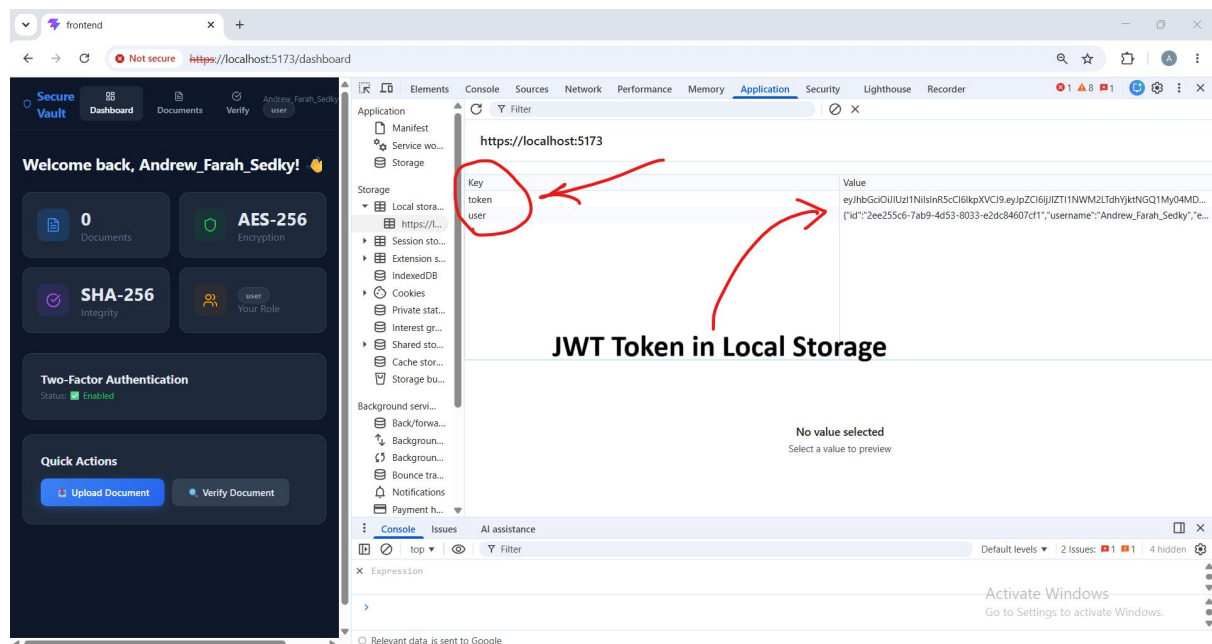


5.2 JWT Authentication

After successful login, the server issues a JSON Web Token (JWT) signed with a secret key. The token contains the user ID and role, and expires after 24 hours. All protected API endpoints require this token in the Authorization header.

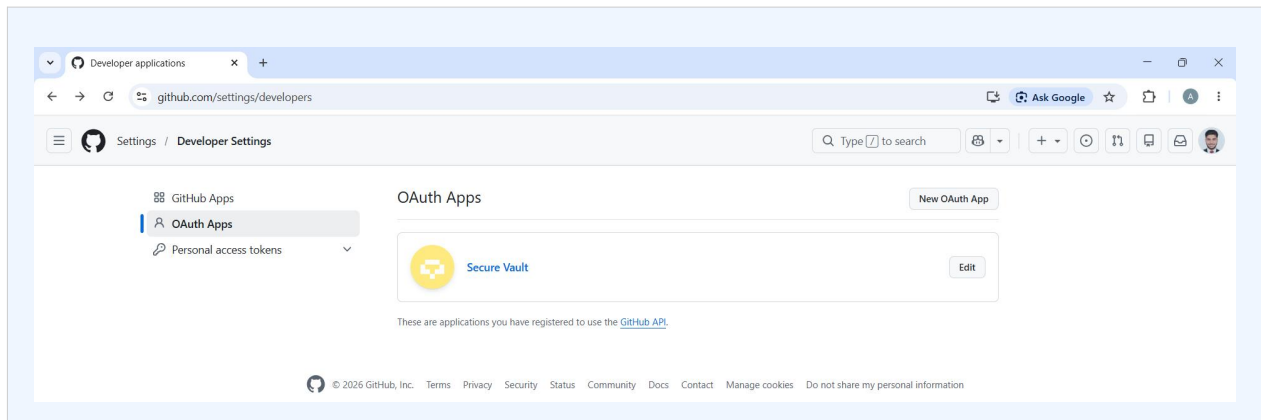


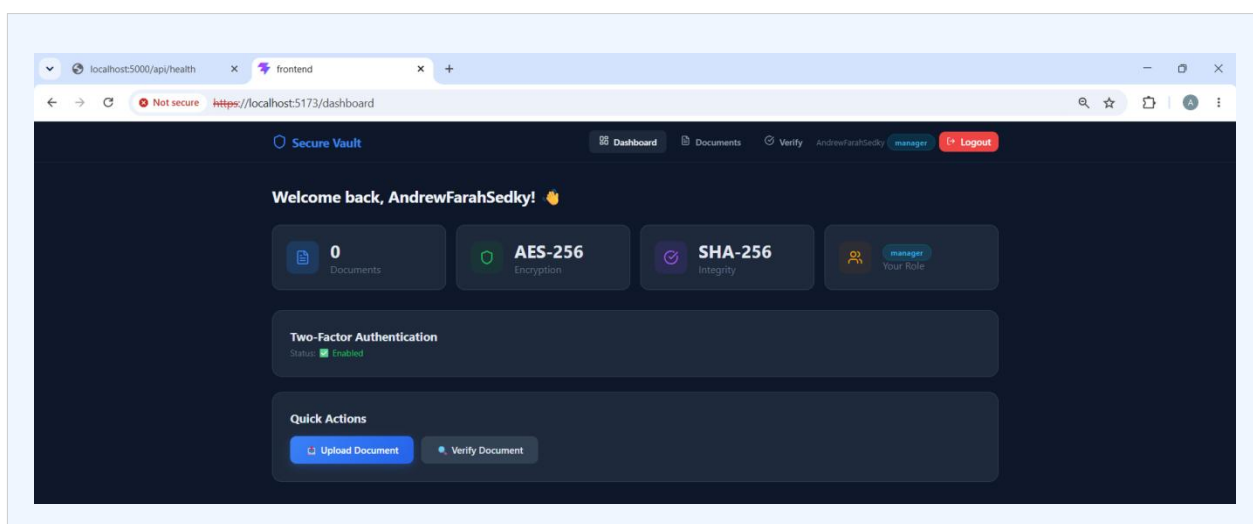
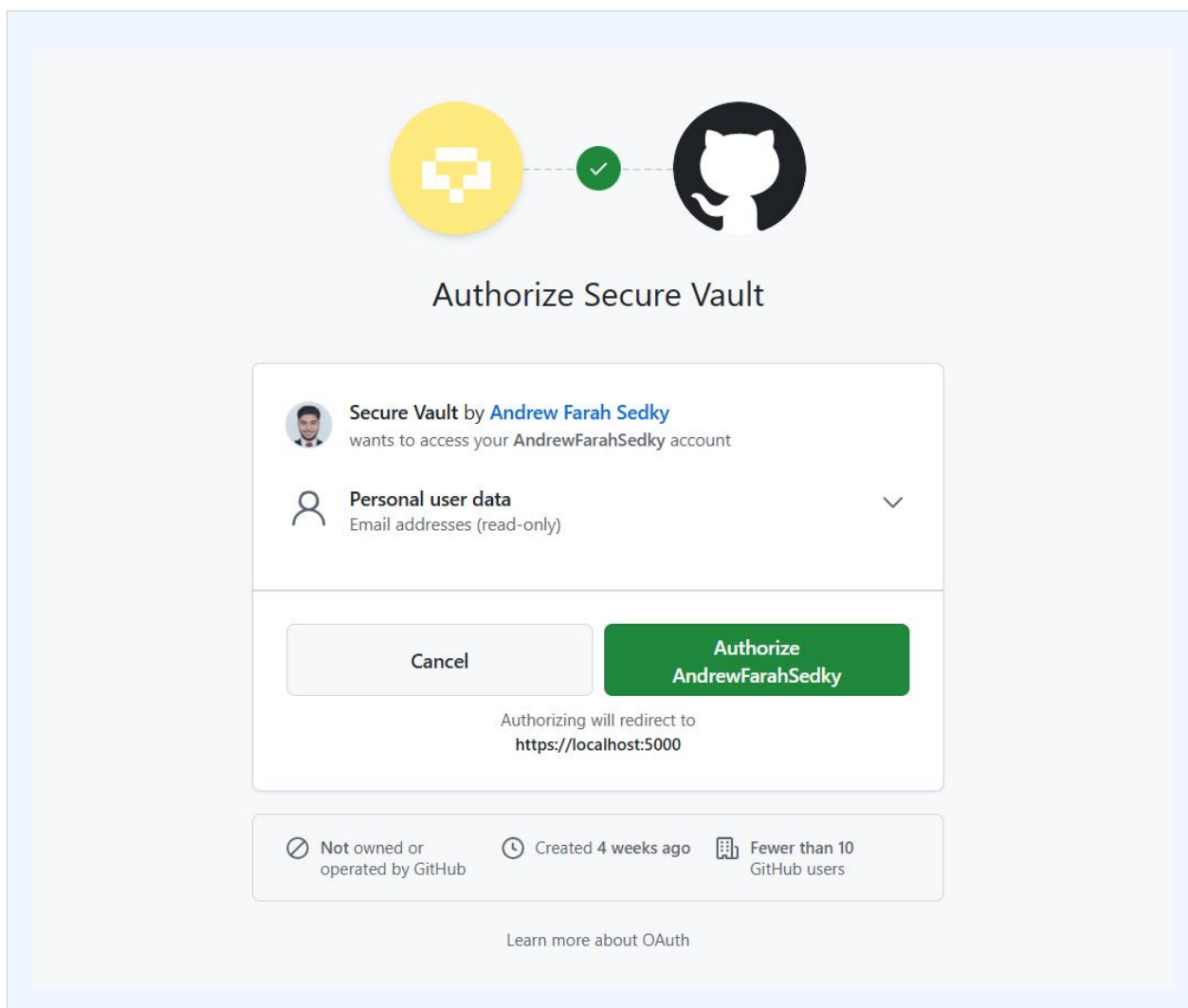




5.3 OAuth Login (GitHub)

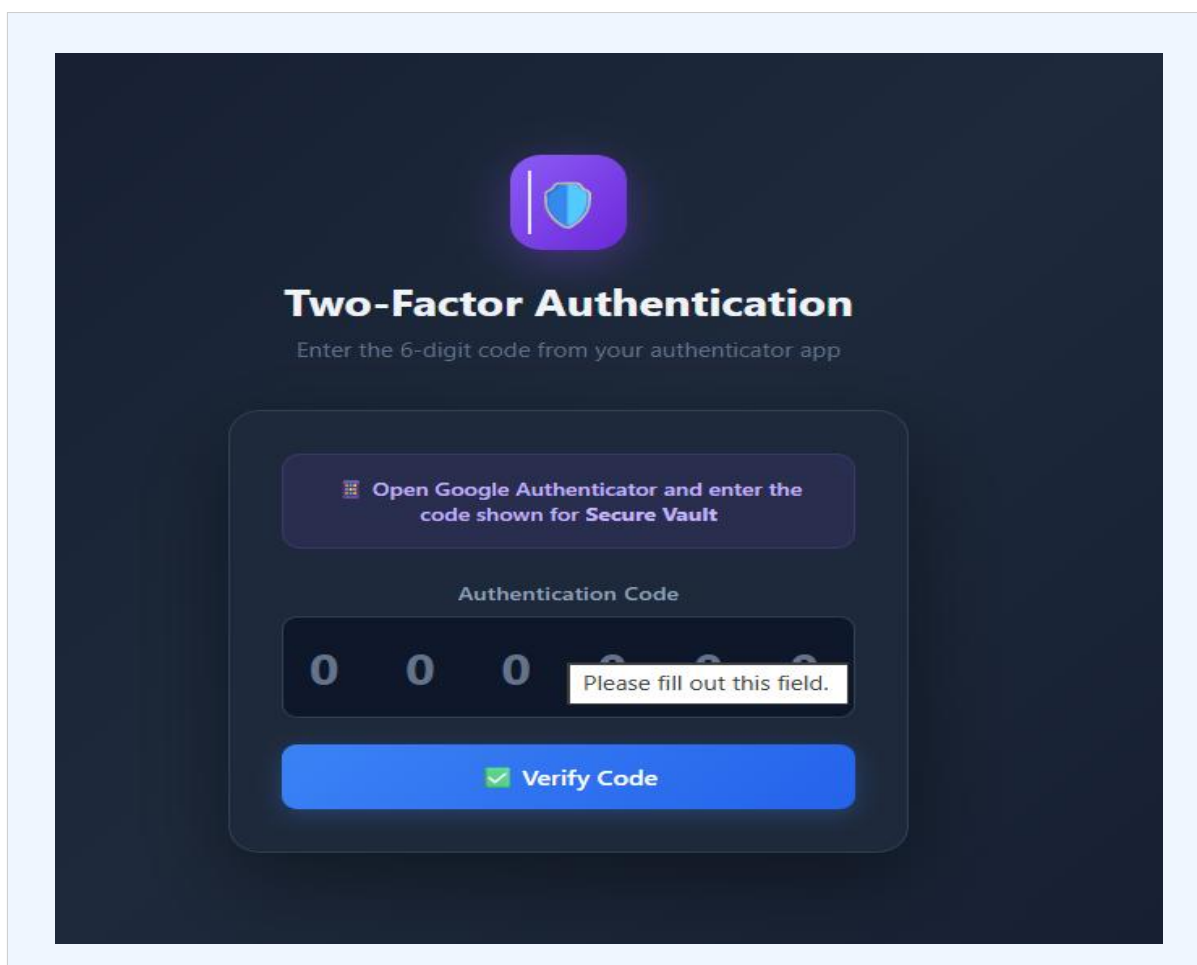
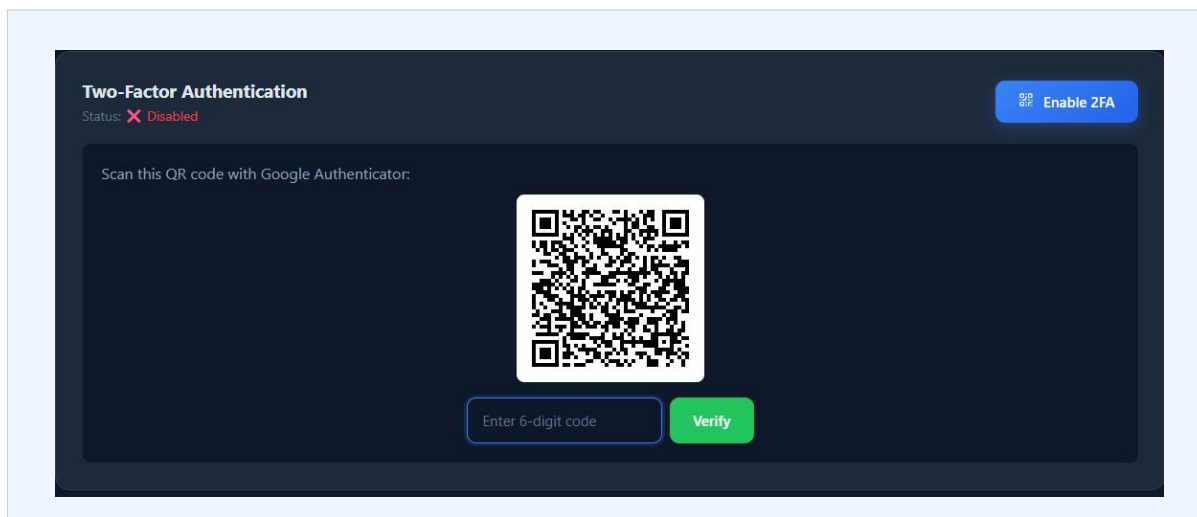
Users can authenticate using their GitHub account via OAuth 2.0. The system uses Passport.js with the GitHub strategy. Upon successful OAuth authentication, the server creates or retrieves the user record and issues a JWT token.

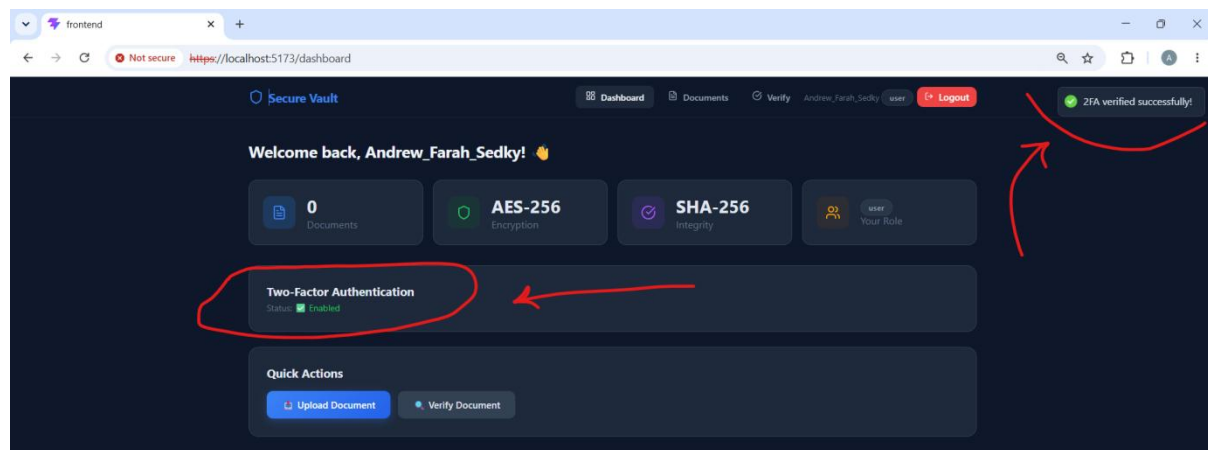




5.4 Two-Factor Authentication (2FA)

The system supports TOTP-based Two-Factor Authentication using the speakeasy library, compatible with Google Authenticator. Users can enable 2FA from the Dashboard by scanning a QR code. On subsequent logins, users must enter a valid 6-digit TOTP code.

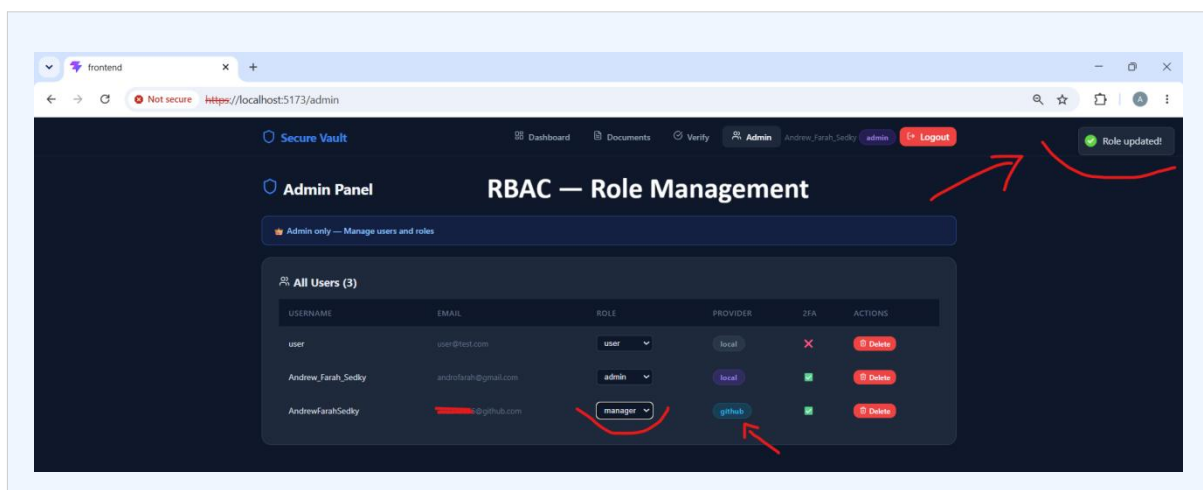




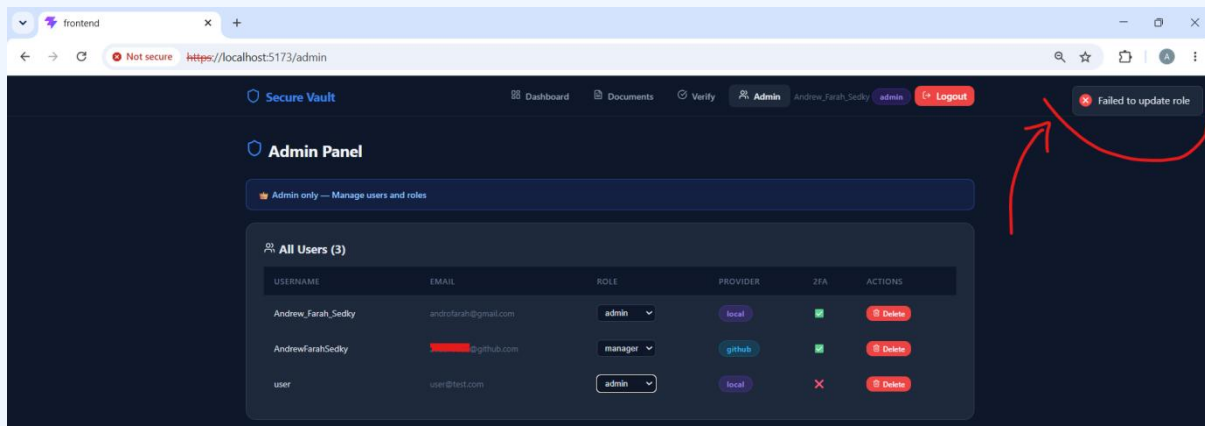
5.5 Role-Based Access Control (RBAC)

The system implements three user roles with different permissions:

Role	Permissions	Access Level
Admin	Manage all users and roles, view all documents	Full system access
Manager	Review and verify documents of all users	Elevated access
User	Upload, view, download, and delete own documents	Standard access



Role update failed because a non-admin user attempted to update a role.

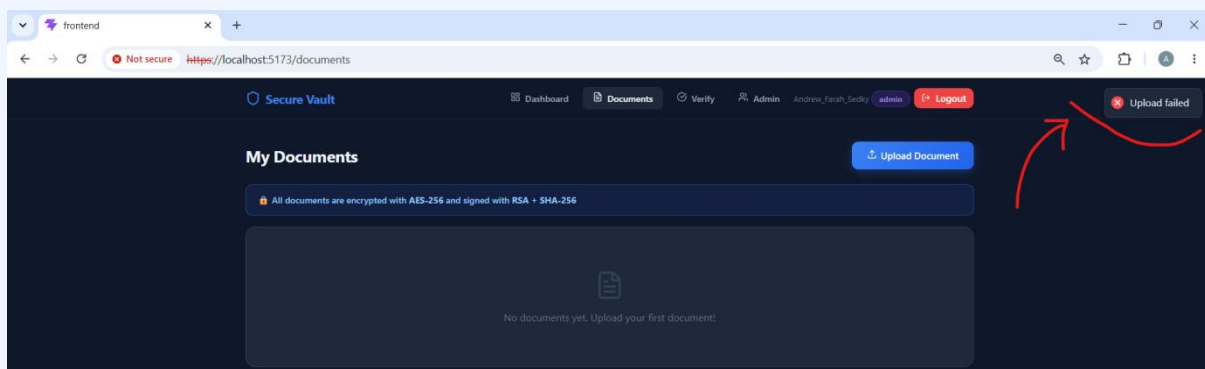


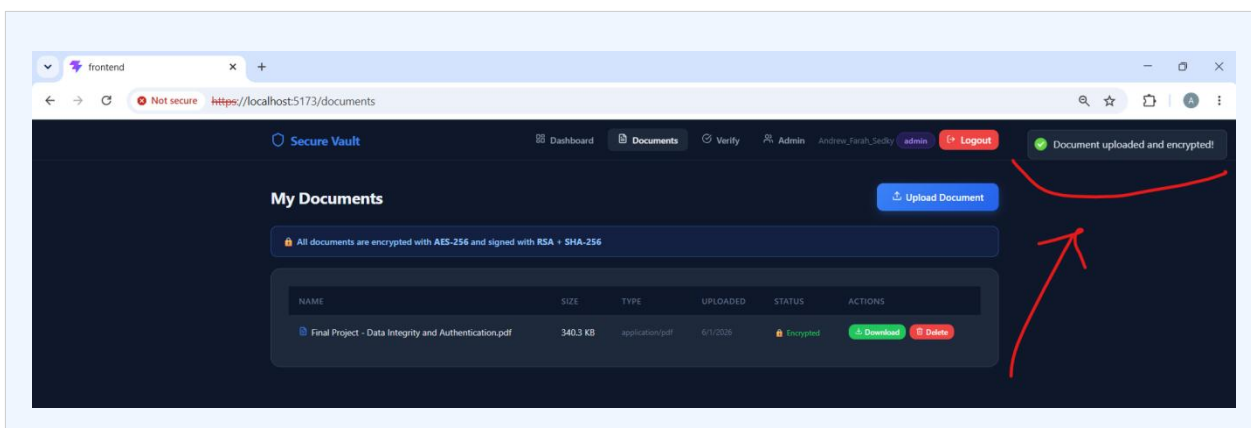
6. Document Management

6.1 Document Upload

Users can upload documents through the web interface. The system validates file types and sizes before processing. Allowed formats include PDF, JPEG, PNG, TXT, DOC, and DOCX. Maximum file size is 10 MB.

The system rejected the upload attempt as the file format was not among the allowed types (PDF, JPEG, PNG, TXT, DOC, DOCX), demonstrating the file type validation mechanism.



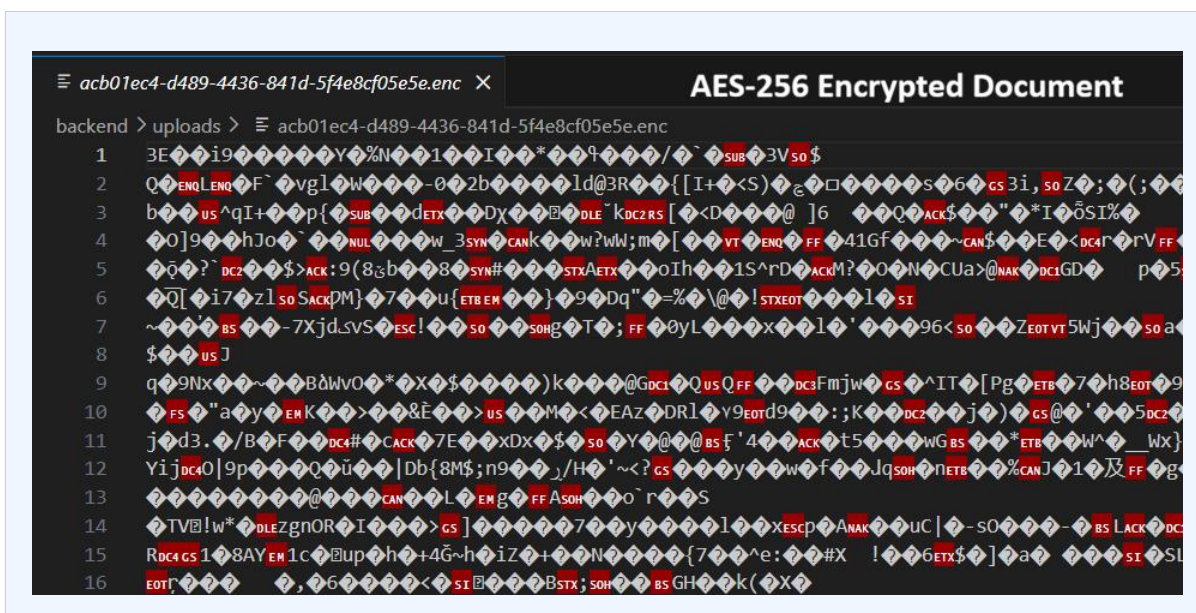


6.2 Document Encryption (AES-256)

Every uploaded document is encrypted using AES-256-CBC before being saved to the filesystem. The process works as follows:

- A random 16-byte Initialization Vector (IV) is generated for each file
- The document is encrypted using AES-256-CBC with the IV and a 32-byte server key
- The IV is prepended to the encrypted file and stored with a .enc extension
- The original unencrypted file is deleted immediately after encryption

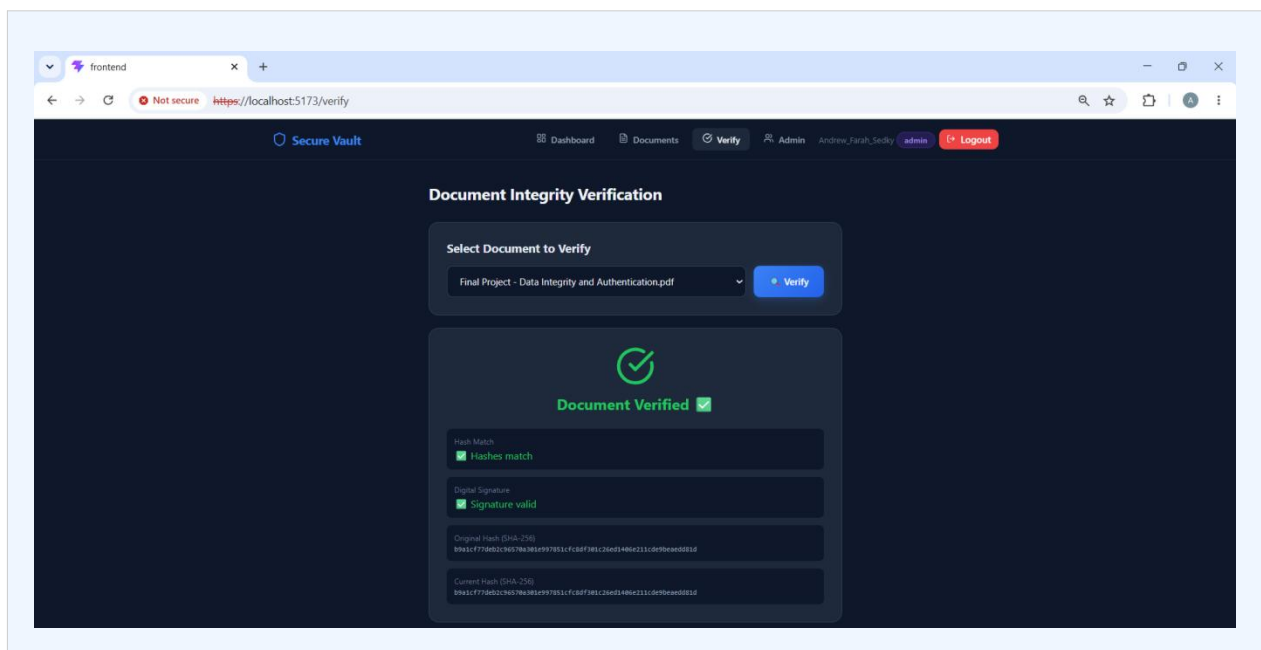
This ensures documents cannot be read directly from storage even if the filesystem is compromised.

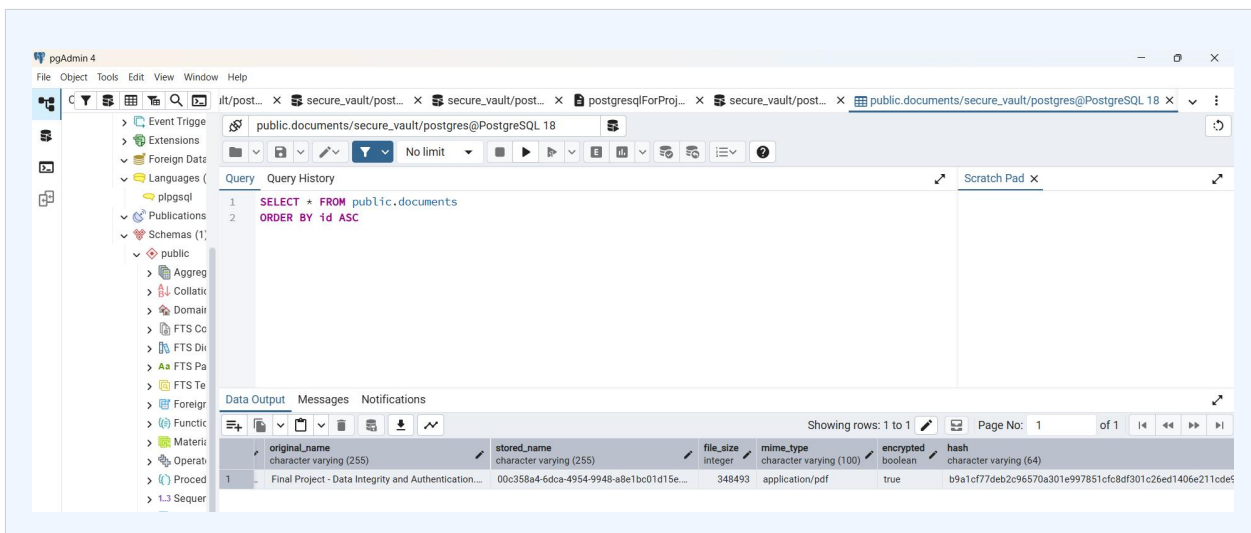


7. Digital Signatures & Integrity Verification

The system implements a complete document integrity verification pipeline using cryptographic techniques:

Step	Description
1. Hash Generation	A SHA-256 hash is computed from the original file before encryption
2. Digital Signing	The hash is signed using RSA-2048 private key (stored in certs/private.pem)
3. Storage	Both hash and signature are stored in the database with the document metadata
4. Verification	On verify request: decrypt file, compute current hash, compare with stored hash, verify RSA signature with public key
5. Tamper Detection	If the encrypted file is modified, the hash will not match — tampering is detected





8. HTTPS & Secure Communication

The application is configured to run over HTTPS using a self-signed SSL certificate generated with mkcert. HTTPS ensures that all data transmitted between the client and server is encrypted using TLS, preventing eavesdropping and man-in-the-middle attacks.

- SSL certificate and private key are stored in backend/certs/
- The Node.js HTTPS server loads the certificate at startup
- The browser displays a padlock icon confirming the secure connection

```
User@DESKTOP-6TK9AVR MINGW64 /d/The university/Level 3 materials/The Semester 2/Data Integrity and Authentication/Final Project/secure-vault/backend
C:\$ npm run dev

> backend@1.0.0 dev
> nodemon src/app.js

[nodemon] 3.1.14
[nodemon] to restart at any time, enter `rs`
[nodemon] watching path(s): *.*
[nodemon] watching extensions: js,mjs,cjs,json
[nodemon] starting `node src/app.js`
◇ injected env (16) from .env // tip: # custom filepath { path: '/custom/path/.env' }
◇ injected env (0) from .env // tip: # enable debugging { debug: true }
◇ injected env (0) from .env // tip: # multiple files { path: ['.env.local', '.env'] }
◇ injected env (0) from .env // tip: # auth for agents [www.vestauth.com]
◇ injected env (0) from .env // tip: # suppress logs { quiet: true }
◇ injected env (0) from .env // tip: # override existing { override: true }
✔ Database connected
🔒 HTTPS Server running on port 5000
```

```
User@DESKTOP-6TK9AVR MINGW64 /d/The university/Level 3 materials/The Semester 2/Data Integrity and Authentication/final Project/secure-vault/frontend
$ npm run dev

> frontend@0.0.0 dev
> vite

VITE v8.0.12 ready in 303 ms

→ Local: https://localhost:5173/
→ Network: use --host to expose
→ press h + enter to show help
```

9. MITM Traffic Analysis — Wireshark Demo

To demonstrate the importance of HTTPS, we captured network traffic using Wireshark under both HTTP and HTTPS conditions.

9.1 HTTP Traffic (Before HTTPS)

With the server running on HTTP, login credentials were sent in plain text. Wireshark captured the TCP stream and clearly showed the email and password fields readable in the packet data.

The screenshot displays the Wireshark interface with a packet capture of an HTTP request. The packet list on the left shows a packet from 192.168.1.100 to 192.168.1.1 on port 5173. The packet details pane on the right shows the HTTP request structure, including the request line, headers, and body. The body contains a JSON object with email and password fields, which are highlighted in red and labeled with a red arrow. The packet bytes pane on the right shows the raw data of the packet.

Wireshark — HTTP Plain Text ⚠

Packet 915: 76 bytes on wire (60 captured) [Capture filter: null]

Internet Protocol Version 6, Src: 192.168.1.100, Destination: 192.168.1.1

Transmission Control Protocol, Src Port: 5900, Destination Port: 5173

HTTP 1.1 200 OK

Content-Type: application/json

Content-Length: 68

ETag: W/"44-VI8M9E/OXG01/m64Fiy0YiW8"

Date: Wed, 13 May 2020 23:28:49 GMT

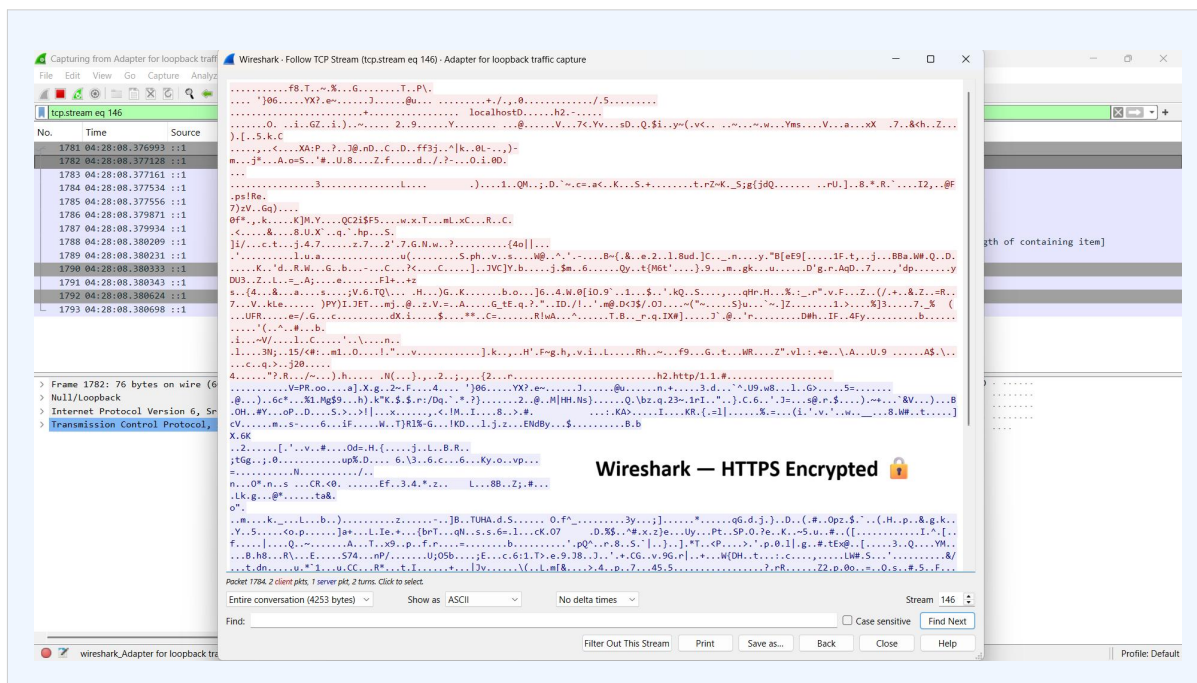
Connection: keep-alive

Keep-Alive: timeout=5

{\"requires2FA\":true,\"userId\":\"49a1a71e-5718-4287-a429-d6922bdceb83\"}

9.2 HTTPS Traffic (After Enabling HTTPS)

After enabling HTTPS, the same login attempt was captured. Wireshark showed only encrypted TLS data — no readable credentials were visible. This confirms that HTTPS effectively protects data in transit against interception.



9.3 Comparison Summary

Aspect	HTTP	HTTPS
Credentials visible	Yes — plain text	No — encrypted
Data encryption	None	TLS/SSL encrypted
MITM vulnerability	High	Protected
Wireshark readable	Fully readable	Encrypted gibberish

10. Database Design

The system uses PostgreSQL with two main tables:

10.1 Users Table

- id — UUID primary key
- username, email — unique identifiers
- password — bcrypt hashed (nullable for OAuth users)
- role — 'admin', 'manager', or 'user'
- oauth_provider, oauth_id — for GitHub/Google login

- two_factor_secret, two_factor_enabled — for 2FA

10.2 Documents Table

- id — UUID primary key
- user_id — foreign key to users
- original_name, stored_name — file names
- file_size, mime_type — metadata
- hash — SHA-256 of the original file
- signature — RSA digital signature of the hash

The screenshot shows the pgAdmin 4 interface with a query executed against the 'public.users' table. The query is:

```
SELECT * FROM public.users
ORDER BY id ASC
```

The results are displayed in a table with the following columns: id, username, email, password, role, and oauth_provider. The data is as follows:

id	username	email	password	role	oauth_provider
07a41a06-f505-4b82-8259-c0c12aa40...	user	user@test.com	\$2b\$12\$5e9Gir4AYRR3fA3BBB8rmeUe7cg6JlVzg3f2jNBytmSEPOHbecla	admin	[null]
0cad98d-48aa-4e66-9e60-553c50ced...	AndrewFarahSedky	@github.com	[null]	manager	github
2ee255c6-7ab9-4d53-8033-e2dc84607...	Andrew_Farah_Sedky	androfarah@gmail.com	\$2b\$12\$w6A967aKa/3fAq6oL8Ga.nb0T0lq0sTN6bzMVCC.FmBWcgmuJy...	admin	[null]

The screenshot shows the pgAdmin 4 interface with a query executed against the 'public.documents' table. The query is:

```
SELECT * FROM public.documents
ORDER BY id ASC
```

The results are displayed in a table with the following columns: id, user_id, original_name, stored_name, file_size, and mime_type. The data is as follows:

id	user_id	original_name	stored_name	file_size	mime_type
0c814f9a-5b2c-4d02-ba30-73cd35622a...	2ee255c6-7ab9-4d53-8033-e2dc84607...	Final Project - Data Integrity and Authentication...	370075e2-25bc-4e36-b49d-f60b5c0f2576...	348493	application/pdf

Red arrows point to the 'id' column in the query and the 'original_name' column in the results table.

Data Output Messages Notifications							
Showing rows: 1 to 1 of 1							
	id [PK] uuid	user_id uuid	original_name character varying (255)	stored_name character varying (255)	file_size integer	mime_type character varying (100)	
1	0c814f9a-5b2c-4d02-ba30-73cd35622a...	2ee255c6-7ab9-4d53-8033-e2dc84607...	Final Project - Data Integrity and Authentication...	370075e2-25bc-4e36-b49d-f60b5c0f2576...	348493	application/pdf	

Data Output Messages Notifications							
Showing rows: 1 to 1 of 1							
	file_size integer	mime_type character varying (100)	encrypted boolean	hash character varying (64)	signature text		
1	b5c0f2576...	348493	application/pdf	true	b9a1cf77deb2c96570a301e997851cfc8df301c26ed1406e211cde9beaedd...	13e277ff59a1eeb58513acc025e3ccd54c9853513e269d034a278030ae817?	

11. How to Run the Project

Prerequisites

- Node.js v20+
- PostgreSQL v15+
- Git

Steps

1. Clone the repository from GitHub
2. Create the database: run database/schema.sql in pgAdmin
3. Configure backend/.env with your database credentials and OAuth keys
4. Install backend dependencies: cd backend && npm install
5. Run backend: npm run dev (starts on port 5000)
6. Install frontend dependencies: cd frontend && npm install
7. Run frontend: npm run dev (opens on https://localhost:5173)

12. Conclusion

The Secure Document Vault System successfully demonstrates a comprehensive implementation of modern security concepts in a real-world web application. The project integrates multiple security layers working together to protect sensitive documents and user data.

Key security achievements include end-to-end encrypted document storage, multi-factor authentication, granular role-based access control, cryptographic integrity verification, and secure HTTPS communication. The Wireshark demonstration clearly illustrates the critical importance of transport layer security.

This project simulates the security architecture found in real enterprise document management systems and provides a solid foundation for understanding applied cryptography and authentication in modern web development.

Githup Repository Link :

<https://github.com/AndrewFarahSedky/Secure-Document-Vault-System.git>